

Security+ 2.3 · Virtualization Vulnerabilities

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.3** —
Virtualization Vulnerabilities (5:29) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Virtualization vulnerabilities include VM escape (breaking out of the VM to the host — rare but severe, breaking isolation); VM sprawl (forgotten VMs without patches or owners); and snapshot reuse (old vulnerable images becoming new instances). Defenses: patch all images, maintain inventory, control snapshots.

High-Yield Core Concepts Tested on Exam

- VM escape: breaks out of the virtual machine to the physical host — critical
- VM sprawl: forgotten machines, unpatched, unowned
- Snapshot reuse can reintroduce old vulnerabilities
- Hypervisor vulnerabilities can affect all hosted VMs
- Proper VM lifecycle management prevents sprawl

Exam Tips & Classic Scenarios

- 'guest machine accesses the host system' = VM escape
- 'forgotten VMs without patches' = VM sprawl
- 'old snapshot used to create new instance' = snapshot reuse risk

Typical Exam Scenario: Scenario: 'an attacker in a VM gains access to the host' = VM escape.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.3 — Virtualization Vulnerabilities)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. Corporate scenario (Virtualization Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'VM escape: breaks out of the virtual machine to the physical machine — severe'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: VM escape: breaks out of the virtual machine to the physical machine — severe...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

2. Corporate scenario (Virtualization Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'VM sprawl: forgotten machine, unpatched, no owner'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: VM sprawl: forgotten machine, unpatched, no owner
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

3. Corporate scenario (Virtualization Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'guest machine accesses the host system' = VM escape'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'guest machine accesses the host system' = VM escape...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

4. Corporate scenario (Virtualization Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Scenario: attacker in the VM gains access to the host = VM escape.' What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Scenario: 'attacker in the VM gains access to the host' = VM escape.
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

5. Corporate scenario (Virtualization Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'VM escape: breaks out of the virtual machine to the physical machine — severe'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: VM escape: breaks out of the virtual machine to the physical machine — severe...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

6. Corporate scenario (Virtualization Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'VM sprawl: forgotten machine, unpatched, ownerless'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: VM sprawl: forgotten machine, unpatched, ownerless.
- D)** Allow shared access among administrators using generic credentials

7. Corporate scenario (Virtualization Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'guest machine accesses the host system' = VM escape'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'guest machine accesses the host system' = VM escape...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (Virtualization Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Scenario: attacker in the VM gains access to the host = VM escape.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Scenario: attacker in the VM gains access to the host = VM escape...
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Virtualization Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'VM escape: breaks out of the virtual machine to the physical machine — severe'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: VM escape: breaks out of the virtual machine to the physical machine — severe...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

10. Corporate scenario (Virtualization Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'VM sprawl: forgotten machine, unpatched, unowned'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: VM sprawl: forgotten machine, unpatched, unowned...

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — Implement the corresponding solution: VM escape: breaks out of the virtual machine to the physical machine — severe....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Virtualization Vulnerabilities): VM escape: breaks out of the virtual machine to the physical machine — severe.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

2) A — Implement the corresponding solution: VM sprawl: forgotten machine, unpatched, no owner.

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Virtualization Vulnerabilities): VM sprawl: forgotten machine, unpatched, no owner. VM sprawl refers to the uncontrolled proliferation of virtual machines, leading to unmanaged, unpatched, and ownerless VMs that pose significant security risks.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

3) A — Implement the corresponding solution: 'guest machine accesses the host system' = VM escape....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Virtualization Vulnerabilities): 'guest machine accesses the host system' = VM escape. VM escape is a critical virtualization vulnerability where an attacker breaks out of the isolated guest VM and gains access to the underlying hypervisor or host system, potentially compromising all other VMs on that host. This is considered severe because it defeats the fundamental isolation boundary of virtualization.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

4) A — Implement the corresponding solution: Scenario: 'attacker in the VM gains access to the host' = VM escape..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Virtualization Vulnerabilities): Scenario: 'attacker in the VM gains access to the host' = VM escape. This is a critical virtualization vulnerability where an attacker compromises the hypervisor from within a guest VM, potentially gaining control over the host and other VMs. Mitigations include keeping hypervisors patched, minimizing VM-to-host interfaces, and using hardware-assisted isolation.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

5) B — Implement the corresponding solution: VM escape: breaks out of the virtual machine to the physical machine — severe....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Virtualization Vulnerabilities): VM escape: breaks out of the virtual machine to the physical machine — severe. A VM escape occurs when an attacker exploits a vulnerability in the hypervisor or virtualization software to break out of the isolated VM and gain access to the host system or other VMs. This is a critical risk because it compromises the entire virtualization infrastructure.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) C — Implement the corresponding solution: VM sprawl: forgotten machine, unpatched, ownerless..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Virtualization Vulnerabilities): VM sprawl: forgotten machine, unpatched, ownerless. VM

sprawl is a virtualization vulnerability where unmanaged VMs increase attack surface; the appropriate control is to implement the corresponding solution, such as VM lifecycle management, regular patching, and ownership tracking.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

7) A — Implement the corresponding solution: 'guest machine accesses the host system' = VM escape....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Virtualization Vulnerabilities): 'guest machine accesses the host system' = VM escape. A VM escape occurs when an attacker compromises a guest virtual machine and then exploits a vulnerability in the hypervisor to gain access to the host system or other VMs. This is a critical virtualization vulnerability because it breaks the isolation boundary. The correct mitigation includes keeping hypervisors patched, minimizing guest-to-host interfaces, and using security features like Intel VT-d or AMD-Vi.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

8) C — Implement the corresponding solution: Scenario: attacker in the VM gains access to the host = VM escape....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Virtualization Vulnerabilities): VM escape occurs when an attacker compromises the hypervisor from within a guest VM, gaining access to the host and other VMs. Mitigations include hypervisor patching, minimizing VM-to-host interfaces, and network segmentation.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials*: Destroys individual

accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) B — Implement the corresponding solution: VM escape: breaks out of the virtual machine to the physical machine — severe....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Virtualization Vulnerabilities): VM escape: breaks out of the virtual machine to the physical machine — severe. VM escape is a critical vulnerability where an attacker exploits a flaw in the hypervisor to break out of the isolated guest VM and gain access to the host system, potentially compromising all other VMs and the underlying infrastructure.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) D — Implement the corresponding solution: VM sprawl: forgotten machine, unpatched, unowned....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Virtualization Vulnerabilities): VM sprawl: forgotten machine, unpatched, unowned.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.